

Top 10 web hacking techniques of 2025: call for nominations



James Kettle
Director of Research
[@albinowax](#)



Published: Tuesday, 6 January 2026 at 15:31 UTC

Updated: Friday, 16 January 2026 at 14:11 UTC



Update: nominations are now closed, and voting is live! [Cast your vote here](#)

Over the last year, security researchers have shared a huge amount of work with the community through blog posts, presentations, and whitepapers. This is great, but it also means genuinely reusable techniques can get buried, and even flashy findings eventually get eclipsed as everyone chases the next shiny logo.

Since 2006, the community has come together each year to turn that firehose into two useful resources:

- A lightly curated list of notable web security research from the last year
- A focused top ten of the most valuable, must-read work

If you want to dig through past nominees and winners or learn more about the project history, check out the full project archive. Otherwise, read on to find out how to make your nominations for 2025.

This year, we'll target the following timeline:

Timeline

- Jan 6-13: Collect community nominations for the top research from 2025
- Jan 14-21: Community votes on nominations to build a shortlist of the top 15
- Jan 22: Launch panel vote on shortlist to select and order the 10 finalists
- Feb 03: Publish top 10 web hacking techniques of 2025!

What should I nominate?

The aim is to highlight research containing novel, practical techniques that can be re-applied to different systems. Individual vulnerabilities like log4shell are valuable at the time but typically age poorly, whereas underlying techniques such as JNDI Injection can be reapplied to great effect. Nominations can also be refinements to already-known attack classes, such as Exploiting XXE with Local DTD Files. For further examples, you might find it useful to check out previous year's top 10s.

Making a nomination

To submit, simply provide a URL to the research, and an optional brief comment explaining what's novel about the work. Feel free to make as many nominations as you like, and nominate your own work if you think it's worthy!

[Click here to submit a nomination](#)

Please note that I'll filter out nominations that are non-web focused, just tools, or not clearly innovative to keep the number of options in the community vote manageable. We don't collect email addresses - to get notified when the voting stage starts, follow [@PortSwiggerRes](#) on [X](#), [LinkedIn](#), or [BlueSky](#).

Join the community

We'd love to hear from you! If you have any questions or you'd like to discuss this year's batch of research, [join us in the #research channel](#) on the PortSwigger Discord.

Nominations - last updated 2026-01-09

I've made a few nominations myself to get things started, and I'll update this list with fresh community nominations every few days. I've included AI-assisted summaries of each entry.

[Eclipse on Next.js: Conditioned exploitation of an intended race-condition](#)

Racing Next.js's response-cache batcher by forcing disparate failing requests to collide on a shared error cache-key, leaking a transient pageProps HTML variant that can then be externally cached for poisoning-to-SXSS despite prior fixes.

[Next.js, cache, and chains: the stale elixir](#)

Chaining a spoofable framework-internal header with Next.js data-request mechanisms to force-cache SSR JSON as HTML, enabling cache-poisoning DoS and stored XSS via stale-while-revalidate.

[Unexpected security footguns in Go's parsers](#)

Chaining Go's case-insensitive JSON key matching, last-wins duplicate keys, and XML's tolerance for leading/trailing garbage to craft cross-format polyglot inputs that different services/parsers interpret differently, enabling authz/authn bypasses.

[HTTP/1.1 must die: the desync endgame](#)

Leveraging Expect handling quirks and early-response gadgets to turn 0.CL deadlocks into reliable double-desync request smuggling that enables response queue poisoning and cross-tenant cache/content

hijacking.

Under the Beamer

Chaining Chromium HTMLCollection DOM clobbering with a library-driven node-removal gadget to null out an escaping function at runtime, then pivoting into an innerHTML iframe-attribute injection sink to bypass DOMPurify and get XSS.

Opossum Attack

Cross-protocol application-layer desynchronization by MITM-switching a victim's implicit TLS connection onto an opportunistic TLS upgrade endpoint to inject pre-handshake messages and permanently misalign request/response streams.

The Fragile Lock: Novel Bypasses For SAML Authentication

Void Canonicalization: forcing canonicalization to error so signature-digest code treats the signed data as empty, combined with parser namespace/attribute inconsistencies to make signature verification and assertion processing diverge for full SAML auth bypass.

Funky chunks: abusing ambiguous chunk line terminators for request smuggling

Abusing chunked-body line-terminator ambiguity inside ignored chunk extensions and oversized-chunk spill to create new request-smuggling differentials (including the newly identified EXT.TERM and spill-based variants) without relying on Content-Length vs Transfer-Encoding confusion.

Funky chunks – addendum: a few more dirty tricks

New HTTP request smuggling primitives exploiting chunked parsing discrepancies via two-byte chunk-body terminator overreads and ambiguous trailer-section newline handling (including request merging enabled by early-response gadgets).

Cross-Site WebSocket Hijacking Exploitation in 2025

Leveraging CSWSH via WebSocket-accessible GraphQL to bypass preflight-gated CSRF protections, plus showing that Private Network Access doesn't apply to WebSockets so cross-origin WebSockets can still reach private-IP services.

SVG Filters - Clickjacking 2.0

Abusing SVG filter pipelines on cross-origin iframes to read selected pixels and implement logic-gated, multi-step interactive clickjacking with exfiltration via user-scanned QR codes generated entirely inside the filter.

Nonce CSP bypass using Disk Cache

Forcing bfcache to fall back to disk cache to reuse a leaked CSP nonce (via CSS exfiltration) while recaching only the injectable fetched content through cache-key manipulation, enabling nonce-based CSP bypass.

Novel SSRF Technique Involving HTTP Redirect Loops

Exploiting redirect-loop status-code variation (cycling uncommon 3xx responses) to trigger an application error state that leaks the full SSRF redirect chain and final 200 response.

Lost in Translation: Exploiting Unicode Normalization

Weaponizing Unicode normalization mismatches (virtual confusables/best-fit mappings and

truncation/overflow edge cases) to bypass validation and turn benign input into malicious behavior.

SOAPwn: Pwning .NET Framework Applications Through HTTP Client Proxies And WSDL

Abusing .NET SOAP proxy generation from attacker-supplied WSDL to set a non-HTTP scheme that turns SOAP invocations into arbitrary file writes (and NTLM relay) culminating in webshell/script drop RCE.

Forcing Quirks Mode with PHP Warnings + CSS Exfiltration without Network Requests

Triggering quirks mode via early PHP warnings to relax same-origin stylesheet MIME checks, then using 404-reflected text as a CSS sink plus :valid-based regex matching and frame-counting as a no-request oracle to exfiltrate secrets under CSP.

ORM Leaking More Than You Joined For

Abusing Beego's filter-expression segment-overwrite quirk to smuggle disallowed fields past partial validation, plus Prisma auth bypass via type confusion that coerces user input into operator objects through common request parsers.

Parser Differentials: When Interpretation Becomes a Vulnerability

Exploiting parser differentials—mismatches between how components interpret the same input—to turn benign-looking data into security bypasses.

DOM-based Extension Clickjacking: Your Password Manager Data at Risk

DOM-based extension clickjacking that hides and repositions password-manager autofill UI injected into the page DOM so a single coerced click triggers secret autofill into attacker-controlled fields for exfiltration.

XSS-Leak: Leaking Cross-Origin Redirects

Using Chromium connection-pool exhaustion plus deterministic host-sorting as a timing oracle to infer cross-origin fetch and redirect destinations (including subdomains) without injection.

Google Cloud Account Takeover via URL Parsing Confusion | by Mohamed Benchikh

Exploiting an IPv6-specific multi-`@` userinfo parsing discrepancy between an OAuth redirect validator and the browser to bypass loopback-only allowlists and exfiltrate authorization codes for account takeover.

How I Accessed 1,800 Company Livestreams and Uncovered a New Web Exploit Class: RRE | by Farzan Karimi

Chaining unauthenticated upstream metadata APIs to recursively reconstruct an entitlement workflow and reach protected media streams, guided by entropy-based discovery of the first sensitive reference (RRE).

Exploiting The Not So Misuse-Resistant Authenticated Encryption API of OpenSSL

Abusing AEAD tag-length truncation in OpenSSL bindings to brute-force short tags, then leveraging the resulting nonce-reuse condition to recover the GHASH/Poly1305 subkey and forge/decrypt arbitrary ciphertexts via a format-validity oracle.

Permission Hijacking at Scale

Compromising widely embedded support widgets to inherit and weaponize delegated browser permissions at scale via account-takeover-to-widget-code-injection chains (XSS/HTML injection plus CSP bypasses).

Playing with HTTP/2 CONNECT

Leveraging HTTP/2 CONNECT stream multiplexing to turn misconfigured forward proxies into a high-throughput internal port scanner over a single connection, potentially evading monitoring that can't inspect per-stream tunnels.

Stopping Redirects

Abusing browser navigation-blocking quirks (URL/protocol restrictions, induced error pages plus Navigation API history leakage, redirect-throttling via rapid same-site navigations, and sandboxing without allow-forms to suppress auto-submitted form redirects) to keep OAuth callback codes readable before they're consumed.

ASP.NET MVC View Engine Search Patterns

Chaining arbitrary file-write via path traversal with ASP.NET MVC view resolution to get Razor execution by invoking a routed action (no extension) so the view engine loads and compiles a planted view file despite IIS extension whitelisting.

Bypassing CSP with New Relic Custom Events

Abusing a strict connect-src allowlist by redirecting an auth-token POST to New Relic and then exfiltrating the JSON body via NRQL error-log sampling, enabled by a URL-parsing/authentication discrepancy that treats path-embedded key material as valid.

CRLF Injection Nested Response Splitting CSP Gadget

Chaining CRLF response splitting into a same-origin script load that itself performs a second response split to emit truncated JavaScript, bypassing strict CSP via Content-Length/Transfer-Encoding manipulation ("nested response splitting").

CVE-2025-1974: The IngressNightmare in Kubernetes

Chaining unauthenticated admission-webhook NGINX config injection with abusing client-body buffering plus ProcFS file-descriptor reuse to load a transient in-container shared library via an obscure directive during config testing for RCE.

ReDisclosure: New technique for exploiting Full-Text Search in MySQL (myBB case study)

Bypassing search-term sanitization by abusing MySQL full-text boolean operator parsing and early-exit length checks to turn result-vs-error redirects into a blind oracle for enumerating otherwise-hidden thread titles.

Python Dirty Arbitrary File Write to RCE via Writing Shared Object Files Or Overwriting Bytecode Files

Achieving Python RCE from dirty arbitrary file write by overwriting valid `.pyc`` headers to load injected bytecode without restart, or more powerfully by dropping a compiled extension module that import resolution prefers over `.py`/`.pyc``, optionally forcing a re-import via process reload triggers.

SharePoint ToolShell – One Request PreAuth RCE chain CVE-2025-53770

Chaining a referrer-based auth bypass with an init-phase ToolPane invocation and a generic-wrapper type-confusion to defeat DataSetSurrogateSelector's allowlist, then reaching TemplateParser via a templated safe control to trigger a deserializing gadget for one-request pre-auth RCE.

Prompt Injection Inside GitHub Actions: The New Frontier of Supply Chain Attacks

Prompt-injecting untrusted issue/PR/commit text into AI-agent prompts in CI/CD to coerce privileged tool

execution, enabling secret exfiltration and repository manipulation.

Attacks via a New OAuth flow, Authorization Code Injection, and Whether HttpOnly, PKCE, and BFF Can Help

Leveraging same-origin script execution to steal and replay OAuth authorization responses while “breaking” the redirect flow (e.g., via response-mode switching/window interruption) to perform authorization code injection that bypasses BFF and PKCE by harvesting server-set pre-auth cookies out-of-band.

Blind trust: what is hidden behind the process of creating your PDF file?

Bypassing PDF-renderer path-traversal mitigations via URL-decoding/double-encoding quirks and exploiting PDF-generation resource loaders to trigger phar stream-wrapper deserialization and “security hook runs too late” SSRF.

Impossible XXE in PHP

Chaining libxml2 parameter-entity expansion quirks with PHP stream wrappers and filter-chains to bypass nonet/double-parse/doctype checks, inline a compressed DTD via data:, and exfiltrate files over DNS.

Blind SSTI

Leveraging reflected runtime errors to exfiltrate code/template-evaluation output and using conditional error triggering as a boolean-blind oracle for Code Injection and SSTI without time delays.

Disguises Zip Past Path Traversal

The return of Zip Slip!

Hacking Gemini: A Multi-Layered Approach

Chaining Markdown/HTML linkification and cross-product export layers to flip sanitized links into images and evade URL rewriting, enabling zero/one-click Workspace data exfiltration via indirect prompt injection.

Make XXE Attacks Brilliant Again !!!

Leveraging Windows UNC paths via file/netdoc handlers to exfiltrate multi-line XXE data over SMB when JDK FTP/HTTP OOB channels are newline-sanitized.

Cross-Site ETag Length Leak

Chaining cross-site ETag length variation into a 431-induced navigation failure and detecting it via Chromium history replacement to build an XS-Leak oracle.

Make Self-XSS Great Again

Abusing credentialless iframes’ same-origin access plus login CSRF/clickjacking to turn stored self-XSS into stored XSS, and using fetchLater’s deferred requests to execute authenticated actions later even after the tab closes (bypassing framing limits).

Vega CVE-2025-59840 - Unusual XSS Technique toString gadget chains | Critical Thinking

Abusing implicit `toString` coercion to invoke a global “this.foo(this.bar)” gadget chain that pivots expression-sandbox member access into `eval` for DOM XSS, with a noted variant enabling argumentless function-call WAF bypass via `valueOf`-style coercion.

Fontleak: exfiltrating text using CSS and Ligatures

Abusing CSS-only injection with a crafted ligature font and container queries to turn per-character glyph-

width differences into conditional network requests, plus browser-specific import/font chaining to iterate indices and exfiltrate long text (including inline script secrets) even under common sanitizers.

The Single-Packet Shovel: Digging for Desync-Powered Request Tunnelling

Combining single-packet parallelization with HTTP/2→HTTP/1 downgrade desync to reliably detect and exploit request tunnelling for frontend rule/rewriter bypasses (notably via whitespace-tolerant length-header mutations in major load balancers/CDNs).

Ruby Array Pack Bleed

Triggering an integer signedness wrap in Ruby Array#pack repeat-count parsing to turn the X “back up” directive into a negative shrink that grows the string length and leaks out-of-bounds heap memory.

Racing and Fuzzing HTTP/3: Open-sourcing QuicDraw(H3)

Adapting the last-byte-sync single-packet race technique to HTTP/3 by buffering near-complete requests across many QUIC streams and then releasing them simultaneously via a coordinated FIN “last-byte” burst (Quic-Fin-Sync).

How We Broke Exchanges: A Deep Dive Into Authentication And Client-Side Bugs

Abusing production-whitelisted localhost OAuth origins/redirects on mobile by running a malicious loopback webserver to silently capture tokens via auto-reauthentication, plus exploiting mixed-content CORS allowing credentialed requests from insecure subdomains via MITM with browser-specific cookie behavior.

Client Side Path Traversal (CSPT) Bug Bounty Reports and Techniques

Chaining client-side path traversal in SPA/REST fetch routing (via backslash/double-encoding normalization) with open redirects or user-uploaded JSON to spoof API responses and reach DOM XSS/URL-leak-driven OAuth takeover.

PermissionJacking: How a Subtle Bug in Safari Could Lead to Camera Hijacking

Clickjacking Safari’s unfocused, still-clickable TCC prompts by overlaying them with a pop-up and using rapid resize race-condition flicker or double-click window-closing to misdirect clicks into granting camera/mic/location permissions.

The Story of a Perfect Exploit Chain: Six Bugs That Looked Harmless Until They Became Pre-Auth RCE in a Security Appliance

Chaining Nginx route exposure, a hard-coded JWT signing secret, leaked internal API keys, an SSRF URL-concatenation trick to reach host-only endpoints that mint an admin session, and finally a rule-engine eval sink made reachable by importing a tampered encrypted rule package using a static AES key to bypass validation for pre-auth RCE.

VESTA Admin Takeover by exploiting bash \$RANDOM limitations

Predicting password-reset tokens by exploiting reduced Bash \$RANDOM seed entropy (timestamp XOR without bit-shifting) to shrink the brute-force space to a feasible time window and achieve admin takeover.

Astro framework and standards weaponization

Weaponizing unvalidated forwarded headers to take over server-side URL construction and exploit WHATWG parser edge-cases to bypass path-based middleware and even whitelist patches, enabling SSRF and cache-poisoning SXSS.

[MadeYouReset Technical Details - How \(and Why\) It Works?](#)

Triggering server-initiated HTTP/2 stream resets via stream-scoped protocol errors after request admission to bypass MAX_CONCURRENT_STREAMS and drive unbounded backend work for DoS

[CVE-2025-26788: Passkey Authentication Bypass in StrongKey FIDO Server](#)

Authentication bypass by swapping the non-discoverable WebAuthn flow's credential binding so a challenge issued for a victim's username can be satisfied with the attacker's passkey, yielding account takeover.

[Novel SQL Injection Technique in PDO Prepared Statements](#)

Triggering SQLi by abusing PDO emulated-prepare SQL-scanner misparsing—using null bytes and escape/comment boundary tricks to make user-controlled text get reinterpreted as bind placeholders, including cross-dialect issues in older unified parsers.

[Temenos OFS Field Injection: Revealing a Hidden Financial Attack Vector](#)

CSV Injection but different!

[The Quiet Side Channel... Smuggling with CL.0 for C2](#)

Using CL.0 desync with GET bodies to globally poison cached 3xx redirects so the Location header becomes a stealth C2 side channel.

[Fuzzing WebSockets for Server-Side Vulnerabilities](#)

State-aware WebSocket fuzzing that replays prerequisite handshake messages, isolates each payload in a fresh connection, then correlates all asynchronous responses captured within a time window using behavior-based anomaly metrics.

[how to hack discord, vercel and more with one easy trick](#)

Abusing server-side MDX evaluation for RCE, then leveraging cross-tenant static asset fetching and URL-encoded path traversal to trigger one-click XSS on customer domains and bypass the patch.

[The minefield between syntaxes: exploiting syntax confusion](#)

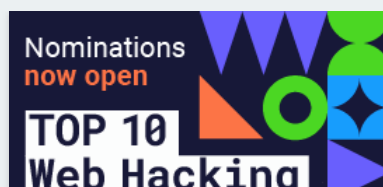
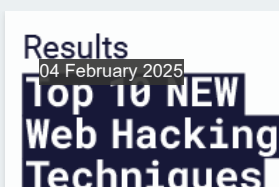
Chaining multi-parser “syntax confusion” tricks—abusing divergent URL/port normalization and multipart Content-Disposition parameter parsing to turn constrained SSRF/blind file read and cache poisoning into reflected content injection and arbitrary file access.

[Top 10 Hacking Techniques](#)

[top-10-techniques](#)

[← Back to all articles](#)

Related Research





Burp Suite

Web vulnerability scanner
Burp Suite Editions
Release Notes

Vulnerabilities

Cross-site scripting (XSS)
SQL injection
Cross-site request forgery
XML external entity injection
Directory traversal
Server-side request forgery

Customers

Organizations
Testers
Developers

Company

About
Careers
Contact
Legal
Privacy Notice
Modern Slavery Statement

Insights

Web Security Academy
Blog
Research
Engineering



© 2026 PortSwigger Ltd.

